

ICT Third-Party Provider Onboarding Framework

DORA Articles 28–44 · Full Lifecycle · Section I: Onboarding & Contractual Controls · Section II: CTPP Oversight

Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | CISM | CISSP | Regulatory context: DORA (EU) 2022/2554, BaFin BAIT 2021, MaRisk AT 9, §25b KWG, EBA/ESMA RTS & ITS | June 2026

Purpose

This framework sets out Musterbank GmbH's end-to-end process for onboarding, managing, monitoring and offboarding ICT third-party service providers (ICT TPPs) in full compliance with DORA Articles 28–44, applicable EBA/ESMA technical standards, BaFin BAIT, MaRisk AT 9, and §25b KWG. It covers both Section I of Chapter V (Articles 28–30 — general principles, concentration risk, and contractual requirements) and Section II (Articles 31–44 — the CTPP Oversight Framework).

The framework applies to all ICT TPPs providing services to Musterbank, with enhanced obligations for those supporting Critical or Important Functions (CIFs). It is consistent with the Musterbank ICT Risk Register (June 2026), DORA Gap Analysis (June 2026), and the DORA Capstone Scenario (June 2026).

Article	Title	Section	Applies to
Art. 28	General principles — ICT third-party risk management	I	All ICT TPPs
Art. 29	Preliminary assessment of ICT concentration risk	I	All ICT TPPs
Art. 30	Key contractual provisions	I	CIF-supporting TPPs
Art. 31	Designation of Critical ICT Third-Party Providers (CTPPs)	II	ESAs / CTPPs
Art. 32	Structure of the Oversight Framework	II	ESAs / CTPPs
Art. 33	Tasks of the Lead Overseer	II	Lead Overseer / CTPPs
Art. 34	Operational coordination between Lead Overseers	II	ESAs internal
Art. 35	Powers of the Lead Overseer	II	Lead Overseer / CTPPs
Art. 36	Exercise of powers outside the Union	II	Third-country CTPPs
Art. 37	Request for information	II	Lead Overseer / CTPPs
Art. 38	General investigations	II	Lead Overseer / CTPPs
Art. 39	Inspections	II	Lead Overseer / CTPPs
Art. 40	Ongoing oversight	II	Lead Overseer / CTPPs
Art. 41	Harmonisation of oversight conditions	II	ESAs / RTS
Art. 42	Follow-up by competent authorities	II	National supervisors
Art. 43	Oversight fees	II	CTPPs
Art. 44	International cooperation	II	ESAs / third countries

Disclaimer: This framework was prepared for portfolio demonstration purposes using a fictional entity (Musterbank GmbH). DORA article references are based on Regulation (EU) 2022/2554 and applicable EBA/ESMA technical standards as of June 2026. Nothing here constitutes legal advice.

SECTION I — ICT Third-Party Risk Management | Articles 28–30 | General Principles · Concentration Risk · Contractual Requirements

1. Strategy & Policy — Art. 28(1)–(2)

BAIT §9, §10 | MaRisk AT 9 | §25b KWG | RTS Mandate #7

Before any ICT TPP is onboarded, Musterbank must have a board-approved ICT third-party risk strategy and policy in place. Art. 28(1) requires ICT third-party risk to be managed as an integral component of the overall ICT risk framework. Art. 28(2) requires a written policy covering the full provider lifecycle, approved by the management body.

Requirement	Musterbank Implementation	Evidence Required
Board-approved ICT third-party risk strategy (Art. 28(1))	Strategy documented as part of the Digital Operational Resilience Strategy (Art. 6(7)); includes third-party risk appetite, concentration risk limits, and tiered classification (Critical / Significant / Non-critical); board approval annually.	Board minute; signed strategy document; annual review record
Written policy — full provider lifecycle (Art. 28(2), RTS Mandate #7)	ICT Third-Party Risk Policy covers: planning and pre-contract assessment; due diligence; contracting; ongoing monitoring; sub-outsourcing oversight; exit and termination. Distinguishes CIF-supporting from non-CIF services.	Signed policy; version control; management body approval
CIF inventory — master switch for all Art. 28–30 obligations (Art. 28, EBA ITS)	Critical or Important Function (CIF) register maintained (CIF-REF format). Each ICT service mapped to CIF status before onboarding begins. CIF status drives due diligence depth, contract requirements, and monitoring intensity.	CIF register; board sign-off; Register of Information linkage
Tiered provider classification (Art. 28(2))	All ICT TPPs classified at onboarding: • Critical — supports CIF; full DORA Art. 28–30 obligations • Significant — material service; enhanced due diligence • Non-critical — standard governance	Classification rationale document; risk committee sign-off

2. Pre-Contract Due Diligence — Art. 28(4)

BAIT §9 | MaRisk AT 9.1 | §25b KWG Abs.1

Art. 28(4) requires financial entities to conduct appropriate pre-contract due diligence before entering into any contractual arrangement for ICT services supporting CIFs. The depth of due diligence is proportionate to the CIF classification.

Due Diligence Area	Critical TPP (CIF-supporting)	Significant TPP	Non-critical TPP
Security certifications	ISO 27001, SOC 2 Type II, PCI DSS (if payment-relevant), CSA STAR — verified and dated	ISO 27001 or equivalent — verified	Self-assessment questionnaire
Financial stability	Latest 2 years audited accounts; credit rating check; public filings review	Latest audited accounts	Not required
Sub-processor mapping (Art. 28(2))	Full fourth-party chain documented; material sub-processors identified; audit rights confirmed through chain	Key sub-processors identified	Not required
Data residency & DSGVO	EU data residency confirmed in writing; SCCs / DPA reviewed; cross-border transfer mechanisms verified	DPA reviewed; residency confirmed	DPA in place
Business continuity & DR	BCP/DRP reviewed; last test results obtained; RTO/RPO confirmed against Musterbank requirements	BCP existence confirmed	Not required
Concentration risk assessment (Art. 29)	Concentration risk formally assessed before signing — see Phase 3	Concentration noted	Not required
Exit feasibility	Preliminary exit timeline and data portability assessed before contract signed	Exit consideration noted	Not required

Due Diligence Area	Critical TPP (CIF-supporting)	Significant TPP	Non-critical TPP
BAIT §9 / §25b KWG checklist	Full BaFin outsourcing checklist completed; wesentlich classification confirmed; Auslagerungsregister entry drafted	Wesentlich determination; BaFin notification if required	Standard procurement

Art. 28(4) key principle: Due diligence is not a tick-box questionnaire. For Critical ICT TPPs, Musterbank must verify — not just request — security certifications, sub-processor chains, and exit viability before signing. Documentary evidence is retained for BaFin inspection.

3. Concentration Risk Assessment — Art. 29

BAIT §10 | BaFin Cloud Merkblatt | MaRisk AT 9

Art. 29 requires financial entities to assess ICT concentration risk before entering into contractual arrangements and on an ongoing basis. Concentration risk exists at entity level (one provider supplying multiple critical services) and at sector level (many financial entities relying on the same provider — relevant for BaFin reporting).

Concentration Risk Dimension	Assessment Requirement	Musterbank Action	Reporting
Single-provider concentration (entity level)	Assess whether one provider supplies >X% of critical ICT services; set internal concentration limit in ICT risk appetite	Current position: AWS at 70% of critical ICT services — exceeds internal limit of 55%. Formal concentration risk statement submitted to BaFin. Multi-cloud roadmap active (Azure EU pilot Q3 2026); target ≤55% by end 2027.	Annual — Risk Committee
Single-provider concentration (sector level)	Consider whether the provider is systemically important across the EU financial sector; feeds into ESA CTPP designation criteria (Art. 31)	AWS is a designated/likely CTPP. Musterbank monitors Lead Overseer recommendations on AWS and factors them into ongoing risk decisions.	Annual — BaFin
Geographic concentration	Assess risk if provider's infrastructure is concentrated in one region or jurisdiction	AWS eu-central-1 primary; eu-west-1 DR. Both EU. Geographic concentration within EU accepted; no data outside EU without explicit consent.	Contractual
Sub-outsourcing concentration	Identify common sub-processors used by multiple critical TPPs (e.g. same CDN or DNS provider across multiple vendors)	Sub-processor mapping completed for Critical TPPs. No critical dependency on a single sub-processor identified — review annually.	Annual
Exit feasibility / substitutability	For each Critical TPP: assess how quickly the provider could be replaced and at what cost. Document substitutability rating.	AWS: substitutability rated LOW (exit >12 months, high cost). Exit plan Phase 1 documented (see Phase 7). Substitutability risk accepted by board.	Annual — Board

4. Register of Information — Art. 28(3)

EBA ITS Mandate #8 | §25b KWG
Auslagerungsregister | BAIT §9

Art. 28(3) requires every financial entity to maintain a Register of Information on all contractual arrangements for ICT services. The EBA ITS (Mandate #8) specifies the exact template and data fields. The Register must be submitted to BaFin at least annually (first submission by 30 April 2025) and provided on request.

Register Template Area	Data Fields Required (EBA ITS)	Musterbank Status
Financial entity identification	LEI of reporting entity; entity type; consolidation level (entity / sub-consolidated / consolidated)	✓ Complete
Contractual arrangements	Contract reference number; type; start date; end date; renewal terms; governing law jurisdiction	✓ Complete
ICT third-party providers	Provider name; LEI; headquarters country; corporate group; parent entity	✓ Complete
ICT services provided	Service type classification; description; data processed; storage location (country/region); sub-outsourcing chain	■ In Progress
Functions supported — CIF linkage	Function name; CIF status (critical / important / neither); link to provider and service record	■ In Progress
Sub-outsourcing chains	Sub-processor name; LEI; country; service scope; CIF relevance of sub-outsourced service	■ In Progress
Assessments — substitutability & exit	Substitutability rating; estimated exit timeline; exit plan reference; concentration risk flag	■ In Progress

Register of Information gap (Gap Analysis Pillar 4 — ✗ Missing): The Register does not yet fully meet the EBA ITS RTS template. CIF mapping must be completed first — it is a prerequisite for the function-linkage fields. Target: full submission to BaFin Q3 2026. The Register must be maintained continuously — not assembled annually.

5. Contractual Requirements — Art. 30

Art. 30(2) | RTS Mandate #9 (Subcontracting) |
BAIT §9 | §25b KWG

Art. 30 specifies the mandatory contractual clauses for every arrangement for ICT services supporting a CIF. These are minimum obligations — contracts may be more onerous. For subcontracting, RTS Mandate #9 extends the obligations through the supply chain. The re-papering programme must bring all legacy contracts into compliance.

Art. 30 Clause	Mandatory Content	Musterbank Standard Wording	Status
Art. 30(2)(a) Service description & SLAs	Clear description of all functions and services; service levels; locations where data is processed and stored	Schedule A: full service description; SLA: [X]% availability; data processing location: EU only (specify country/region)	✓ Complete
Art. 30(2)(b) Availability, continuity & performance	Availability commitment; business continuity obligations; incident notification timeline (must align to DORA Art. 19 4h threshold)	SLA availability ≥[X]%; provider notifies Musterbank of major incidents within 4 hours; BCP tested annually; RTO/RPO confirmed	✓ Complete
Art. 30(2)(c) Security — confidentiality, integrity, availability	Provider security obligations; encryption; data protection; personnel security; security incident handling	Provider maintains ISO 27001 / SOC 2 Type II; encryption at rest and in transit; DSGVO Art. 28 DPA incorporated; security incidents notified within 4 hours	✓ Complete
Art. 30(2)(d) Assistance with incident management	Provider must assist Musterbank during ICT incidents — at no additional charge or at pre-agreed cost	Provider provides 24/7 support during Musterbank-declared major incidents; forensic artefacts made available; dedicated incident response team access	✓ Complete

Art. 30(2)(e) Audit & inspection rights	Full audit rights for Musterbank and competent authorities (BaFin, ECB) — including on-site inspections; rights extend through sub-processor chain per RTS #9	Musterbank and BaFin/ECB retain right to inspect provider premises and systems with [X] days notice; third-party audit reports shared on request; audit rights flow to all material sub-processors	✓ Complete
Art. 30(2)(f) Subcontracting conditions (RTS Mandate #9)	Conditions under which CIF-relevant sub-outsourcing is permitted; notification of material changes; Musterbank right to object or exit; full sub-processor chain visibility	Provider may subcontract only listed services; must notify Musterbank 30 days before material sub-processor changes; Musterbank may terminate on material change it objects to	✓ Complete
Art. 30(2)(g) Termination rights & exit assistance	Clear termination rights including for regulatory reasons; minimum exit assistance period; data export and deletion; transition support (at least 12 months for CIF services)	Termination for convenience: [X] days notice; termination for regulatory reasons: immediate; 12-month transition support; data exported in portable format within 30 days; data deletion certificate within 60 days	✓ Complete
Art. 30(2)(h) Cooperation with supervisors & CTPP oversight	Provider must cooperate with ESAs and national supervisors; if designated CTPP — cooperation with Lead Overseer; financial entity must factor Lead Overseer recommendations into its risk decisions	Provider cooperates with BaFin/ECB/ESA supervisory requests; if designated CTPP, Lead Overseer recommendations reviewed by Musterbank Risk Committee and reflected in ongoing monitoring	✓ Complete
Re-papering programme (legacy contracts)	All pre-DORA contracts for CIF-supporting services must be brought into compliance — 're-papered' — as a priority workstream	Re-papering programme active: top 20 critical TPP contracts by Dec 2026. Current Art. 30 coverage: 60%. Target: 100%.	■ In Progress (60% coverage)

6. Onboarding Workflow — End-to-End Process

Art. 28–30 DORA | §25b KWG | BAIT §9

The following gate-based workflow is applied to every new ICT TPP engagement. Each gate must be passed before progressing to the next phase. Critical TPPs require sign-off from IT Risk, Legal, Procurement, and the CRO.

Gate	Phase	Activity	Owner	Output
Gate 1	Request & Classification	Business sponsor submits ICT TPP onboarding request; IT Risk classifies provider (Critical / Significant / Non-critical); CIF determination completed	IT Risk	Classification memo; CIF determination
Gate 2	Concentration Risk Assessment	Art. 29 concentration risk assessment completed; internal concentration limits checked; BaFin notification assessed if wesentlich	IT Risk / CRO	Concentration risk form; BaFin notification if required
Gate 3	Due Diligence	Pre-contract due diligence completed per Phase 2 checklist; security certs verified; sub-processor chain mapped; financial stability confirmed	IT Risk / Procurement	Due diligence report; DD evidence pack
Gate 4	Contract Negotiation	Art. 30 mandatory clauses inserted; DPA / DSGVO Art. 28 processor agreement signed; SLAs agreed; audit rights confirmed; subcontracting conditions set	Legal / Procurement	Signed contract with Art. 30 checklist completed
Gate 5	Auslagerungsregister & Register of Information	Auslagerungsregister entry created (§25b KWG); DORA Register of Information updated per EBA ITS template; BaFin notification submitted if wesentlich Auslagerung	IT Risk / Compliance	Register entries; BaFin notification receipt
Gate 6	Exit Plan	Exit plan documented per Art. 28(7): migration path, timeline (minimum 12 months), data portability confirmed, transition cost estimated, substitutability rated	CTO / IT Risk	Documented exit plan; board review scheduled
Gate 7	Go-Live Approval	All gates 1–6 passed; IT Risk Officer sign-off; CRO approval for Critical TPPs; provider added to annual DORT testing scope if CIF-supporting	CRO / IT Risk	Go-live approval memo; DORT scope update

7. Ongoing Monitoring — Art. 28(6)

BAIT §9 | MaRisk AT 9.2 | Art. 28(6) DORA

Art. 28(6) requires continuous monitoring of ICT TPP performance, risk, and compliance throughout the relationship. Monitoring intensity is proportionate to CIF classification.

Monitoring Activity	Critical TPP (CIF)	Significant TPP	Frequency
SLA performance review	Monthly SLA dashboard; automated alerting on breach	Quarterly review	Monthly / Quarterly
Security posture monitoring	Security ratings platform (e.g. SecurityScorecard); new CVEs tracked; GuardDuty / SIEM alerts monitored	Annual security questionnaire re-run	Continuous / Annual
Certification renewal check	ISO 27001, SOC 2 Type II recertification dates tracked; new reports obtained and reviewed	Annual certificate check	Annual
Sub-outsourcing changes (RTS Mandate #9)	Provider must notify 30 days before material sub-processor changes; IT Risk assesses impact on CIF; right to object or exit exercised if needed	Notify and review	Event-driven
Concentration risk review (Art. 29)	Provider concentration ratio recalculated; reported to Risk Committee; BaFin report updated if material change	Note if concentration increases	Annual
Audit rights exercise	On-site audit or third-party audit commissioned; findings tracked to remediation	Desk-based review	Annual (Critical)

Monitoring Activity	Critical TPP (CIF)	Significant TPP	Frequency
CTPP Lead Overseer recommendations (Art. 42)	If provider is a designated CTPP: Lead Overseer recommendations reviewed; Musterbank reflects unaddressed recommendations in its own risk assessment	N/A unless CTPP	Ongoing
Annual third-party risk review	Full re-assessment of all critical TPP risks; update Register of Information; refresh exit plan; report to Risk Committee	Abbreviated review	Annual

8. Exit Planning & Termination — Art. 28(7)

Art. 28(7) DORA | §25b KWG | BAIT §9 | RTS
Mandate #7

Art. 28(7) requires documented exit strategies for all contractual arrangements for ICT services supporting CIFs. Exit plans must be maintained, tested, and reviewed at least annually. Exit plans are a hard DORA requirement — not aspirational.

Exit Plan Element	Requirement	Musterbank Standard
Migration path	Documented, realistic alternative provider or in-house option	Alternative CSP identified; migration architecture documented; minimum 12-month runway for Critical TPPs
Data portability	Data must be exportable in a usable format; confirmed in contract and tested	Data export format confirmed in contract (Section 5 Art. 30(g)); portability test conducted biennially
Transition cost estimate	Realistic cost estimate for transition to alternative provider	Cost estimate commissioned at onboarding; reviewed annually; board-approved budget provision
Interim operating model	How the entity operates the function during transition period	Manual fallback or interim provider identified; RACI documented; BCP updated to cover transition scenario
Contractual exit assistance	Provider contractually committed to transition support (minimum 12 months for CIF-supporting services)	Art. 30(2)(g) clause inserted: 12-month transition support; data deletion certificate; cooperation with replacement provider
Substitutability rating	Formal assessment of how easily and quickly the provider can be replaced	Rated: High / Medium / Low. Low-rated providers require enhanced exit planning and concentration risk reporting to board
Annual review	Exit plan reviewed and updated at least annually; board sign-off required	Annual review in Q4; CTO and CRO sign-off; changes reflected in Register of Information

SECTION II — CTPP Oversight Framework | Articles 31–44 | Financial Entity Obligations & CTPP Regulatory Supervision

What the Oversight Framework means for a financial entity

Articles 31–44 establish the framework under which the European Supervisory Authorities (EBA, EIOPA, ESMA) directly supervise Critical ICT Third-Party Providers (CTPPs). This is unprecedented: for the first time, EU financial regulators have direct oversight authority over non-financial entities (technology providers). While the primary obligations in Articles 32–44 fall on the ESAs and CTPPs, financial entities carry important secondary obligations — particularly around factoring Lead Overseer recommendations into their own risk decisions.

9. CTPP Designation — Art. 31

EBA / EIOPA / ESMA | Commission Delegated Regulation (EU) 2024/0502

Element	Detail	Musterbank Obligation
Who designates	The three ESAs (EBA, EIOPA, ESMA) jointly designate CTPPs based on quantitative and qualitative criteria including: systemic impact of failure; number and importance of financial entities relying on the provider; degree of substitutability.	Monitor ESA CTPP list (published annually). Identify which of Musterbank's critical ICT TPPs are designated or likely to be designated.
Designation criteria	Systemic importance; cross-border reach; financial sector dependency; substitutability; interconnectedness with other critical infrastructure.	AWS, Microsoft, and major core banking vendors are likely CTPP candidates. Musterbank flags these in its Register of Information.
Opt-in (Art. 31(11))	ICT TPPs not automatically designated may voluntarily apply for CTPP designation.	Monitor whether Musterbank TPPs opt in. Update Risk Register and Register of Information accordingly.
Annual CTPP list	ESAs publish and update the list of CTPPs annually. List available on EBA, EIOPA, and ESMA websites.	IT Risk reviews CTPP list annually. Any Musterbank TPP newly designated triggers enhanced monitoring obligations.

10. Oversight Structure & Lead Overseer Tasks — Art. 32–33

EBA Lead Overseer | Joint Examination Teams (JETs)

Element	What It Means	Financial Entity Impact
Lead Overseer (LO) Art. 32	One of the three ESAs is assigned as Lead Overseer for each CTPP. EBA leads for banking-sector CTPPs (e.g. AWS, Microsoft for banks). EIOPA leads for insurance. ESMA for investment firms.	Musterbank's primary CTPP contacts are governed by the EBA Lead Overseer. BaFin (national competent authority) supports and follows up.
Joint Examination Teams (JETs) Art. 32	JETs are multi-ESA and national authority teams that conduct ongoing oversight activities for each CTPP.	JET findings and recommendations on a CTPP affect Musterbank's own risk assessment and monitoring obligations.
Lead Overseer tasks Art. 33	LO tasks include: annual oversight plan; risk assessment of CTPP; information requests; investigations; inspections; recommendations; periodic penalty payments for non-cooperation.	Musterbank must cooperate with LO information requests relating to its use of a CTPP (Art. 37). Contracts must include cooperation clause.

11. Powers of the Lead Overseer — Art. 34–39

Art. 35 Powers | Art. 37 Information | Art. 38–39 Investigations & Inspections

Article	Power	Description	Entity Obligation
Art. 34	Operational coordination	LOs coordinate oversight activities across ESAs to avoid duplication and ensure consistency.	No direct obligation — awareness only.

Article	Power	Description	Entity Obligation
Art. 35	Powers of the Lead Overseer	LO may: request information; conduct investigations; perform on-site inspections; issue recommendations; impose periodic penalty payments on CTPPs for non-cooperation.	Musterbank must ensure CTPP contracts include obligation to cooperate with LO; must factor LO recommendations into risk decisions (Art. 42).
Art. 36	Powers outside the Union	Oversight powers extend to CTPPs operating from third countries (e.g. US-headquartered hyperscalers with EU operations).	Relevant for AWS (US HQ). Musterbank's contract confirms AWS EU entity cooperates with EU oversight.
Art. 37	Request for information	LO may request information from CTPPs — and from financial entities about their use of a CTPP's services.	Musterbank must be able to respond to BaFin/LO information requests about its use of each CTPP within required timeframes.
Art. 38	General investigations	LO may conduct investigations into CTPPs — including document requests, interviews, and examination of records.	Musterbank cooperates if BaFin requests information as part of an LO investigation.
Art. 39	Inspections	LO may conduct on-site and remote inspections of CTPP premises and systems.	Musterbank's audit rights clause (Art. 30(2)(e)) enables LO-requested inspections. Musterbank facilitates BaFin access to CTPP on request.

12. Ongoing Oversight, Follow-up & International Cooperation — Art. 40–44

Art. 40 Oversight | Art. 42 Follow-up | Art. 43 Fees | Art. 44 International

Article	Content	Financial Entity Obligation
Art. 40 Ongoing oversight	LO conducts continuous oversight of each CTPP against the oversight plan. Includes risk assessments, performance monitoring, and annual oversight reports.	Monitor LO oversight reports and recommendations published for CTPPs Musterbank uses. Feed findings into annual TPP risk review.
Art. 41 Harmonisation of oversight conditions	RTS (Mandate #10) specifies how oversight activities are conducted consistently across all three ESAs — conditions, methodology, cooperation with national authorities.	No direct obligation. Awareness: oversight methodology is standardised — Musterbank can anticipate what a CTPP oversight review will examine.
Art. 42 Follow-up by competent authorities	Where the LO issues recommendations to a CTPP that the CTPP fails to implement, national competent authorities (BaFin) must ensure financial entities using that CTPP take the recommendations into account in their own risk assessments.	Key obligation: If BaFin informs Musterbank of an unaddressed LO recommendation for a CTPP it uses, Musterbank must reflect it in its risk assessment and monitoring. Failure to do so is a supervisory finding. Process: LO recommendation received → IT Risk assesses impact on Musterbank → Risk Register updated → Risk Committee informed → remediation or mitigating controls applied.
Art. 43 Oversight fees	CTPPs bear the cost of their oversight through fees set by delegated act. Fees are charged to the CTPP — not to financial entities.	No direct cost to Musterbank. However, CTPP oversight costs may be passed through indirectly in provider pricing. Monitor for contract price escalation clauses.
Art. 44 International cooperation	ESAs may enter into administrative arrangements with third-country supervisory authorities for CTPPs operating from outside the EU (e.g. US, UK).	Relevant for AWS (US), Microsoft (US), and any UK-based ICT TPPs. Musterbank's contracts confirm EU-entity cooperation obligations apply regardless of third-country HQ.

Art. 42 is the most operationally significant Article 31–44 obligation for a financial entity. A CTPP failing to act on Lead Overseer recommendations is not a problem only for the CTPP — BaFin will expect Musterbank to have identified the gap, assessed the impact, and updated its own risk management accordingly. This must be a standing agenda item in the annual TPP risk review.

MASTER CHECKLIST — DORA Articles 28–44 | Onboarding & Lifecycle Compliance

✓	Requirement	Article / Ref	Owner
■	Board-approved ICT third-party risk strategy and policy covering full lifecycle	Art. 28(1)–(2), RTS #7	CRO / CISO
■	CIF inventory complete; all ICT services mapped to CIF status	Art. 28, EBA ITS	IT Risk
■	Tiered TPP classification in place (Critical / Significant / Non-critical)	Art. 28(2)	IT Risk
■	Pre-contract due diligence completed per Art. 28(4) — proportionate to classification	Art. 28(4)	IT Risk / Procurement
■	Art. 29 concentration risk assessment completed before each Critical TPP engagement	Art. 29	IT Risk / CRO
■	Concentration risk reported to Risk Committee annually; BaFin notified if wesentlich	Art. 29, BaFin Merkblatt	IT Risk / CRO
■	All 8 Art. 30 mandatory clauses inserted in CIF-supporting TPP contracts	Art. 30(2)(a)–(h)	Legal / Procurement
■	Sub-outsourcing conditions and notification rights included — chain audit rights confirmed	Art. 30(2)(f), RTS #9	Legal
■	Re-papering programme active for legacy contracts; target 100% by Dec 2026	Art. 30	Legal / Procurement
■	Register of Information built per EBA ITS template; submitted to BaFin by 30 Apr 2025	Art. 28(3), ITS #8	IT Risk / Compliance
■	Register of Information maintained continuously with named data owner	Art. 28(3)	IT Risk
■	Auslagerungsregister (§25b KWG) entries current; BaFin notifications completed	§25b KWG, BAIT §9	Compliance
■	Exit plans documented for all CIF-supporting Critical TPPs; reviewed annually	Art. 28(7), RTS #7	CTO / IT Risk
■	Data portability tested biennially for Critical TPPs	Art. 28(7)	CTO
■	Ongoing monitoring programme active (SLA, security, certification, sub-outsourcing)	Art. 28(6)	IT Risk / Procurement
■	ESA CTPP list reviewed annually; Musterbank TPP CTPP status tracked	Art. 31	IT Risk
■	CTPP contracts include Lead Overseer cooperation clause	Art. 33, 35	Legal
■	Process in place to factor LO recommendations into Musterbank risk decisions (Art. 42)	Art. 42	IT Risk / CRO
■	Art. 44 third-country cooperation confirmed for non-EU HQ CTPPs	Art. 44	Legal
■	All Critical TPPs included in annual DORT resilience testing programme	Art. 24–27	CISO
■	Annual TPP risk review reported to Risk Committee	Art. 28(6)	CRO / IT Risk

Musterbank GmbH (fictional entity for portfolio purposes) | DORA ICT Third-Party Onboarding Framework | Art. 28–44 | Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | CISM | CISSP | June 2026 | Consistent with: ICT Risk Register v4, DORA Gap Analysis v2, Capstone Scenario v3